

Kerberos en dos minutos

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

Kerberos es como AD autentica sin mandar la password por la red. Al iniciar sesión, el usuario obtiene un TGT (ticket para pedir tickets) del DC. Luego, para usar un servicio, cambia el TGT por un TGS (ticket de servicio). Todo gira en torno a tickets cifrados con claves derivadas de passwords.

Porque esos tickets van cifrados con la clave del usuario o del servicio, y se pueden pedir en situaciones que permiten crackearlos offline: eso es lo que explotan asrep-kerberoast. Además, si robas o falsificas tickets, te haces pasar por otro sin su password.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Es teoría de apoyo para la fase AD (ad-modelo). No hace falta dominarla para atacar, pero entender TGT/TGS te dice por qué funcionan los ataques de roasting y de tickets.

Cómo identificarla

- Puerto 88 abierto: hay Kerberos y por tanto un DC.
- Errores 'KRB_AP_ERR_SKEW' = tu reloj está desincronizado con el DC.
- Hashes que empiezan por \$krb5asrep\$ o \$krb5tgt\$ al hacer roasting.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Sincroniza tu reloj con el DC si ves KRB_AP_ERR_SKEW en cualquier herramienta de Kerberos.

Evidencia esperada: El error de clock skew desaparece y las herramientas de impacket dejan de fallar por tiempo.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
sudo ntpdate $DC_HOST
```

Objetivo y contexto: Sincroniza tu reloj con el DC. Kerberos rechaza tickets si el desfase supera unos minutos; este es el arreglo del clásico error de clock skew.

Resultado esperado: Imprime el ajuste de tiempo aplicado. Tras esto, las herramientas de Kerberos (impacket) dejan de fallar por skew. Alternativa: faketime.

Anatomía de los payloads

La primera prueba es `sudo ntpdate $DC_HOST`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

El error de clock skew desaparece y las herramientas de impacket dejan de fallar por tiempo.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Asegura nombres y hora: Kerberos es muy sensible al reloj (max ~5 min de desfase).
- Con o sin credencial, intenta roasting para sacar tickets crackeables (asrep-kerberoast).
- Crackea los tickets offline para obtener nuevas credenciales.
- Con credenciales de mas nivel, sigue el grafo de permisos hacia Domain Admin.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- No es un entorno AD (no hay puerto 88): Kerberos no aplica.
- Tu reloj y el del DC estan sincronizados y no ves errores de skew: no hace falta tocar nada aqui.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

El sistema de tickets de AD; entender TGT y TGS explica por que existen AS-REP roast y Kerberoasting. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (kerberos)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.